

GUIDE PREMIUM · MY-DTM

Sécuriser son site web

Rançongiciel, défiguration, vol de données, spam : un site n'est jamais « trop petit » pour être attaqué. Voici la méthode claire et concrète pour protéger votre site, vos clients et votre réputation — sans être expert en cybersécurité.

[HTTPS](#) · [Mots de passe & 2FA](#) · [Mises à jour](#) · [Sauvegardes](#) · [En-têtes](#) · [WordPress](#) · [Paiements](#) · [RGPD](#) · [Plan de réaction](#)

© My-DTM Paris — Agence digitale · [my-dtm.fr](#) · [hello@my-dtm.fr](#) · Usage personnel. Revente et redistribution interdites.

Sommaire

1. Pourquoi les PME sont des cibles (le mythe du « trop petit »)
2. HTTPS, TLS & certificats : le socle
3. Mots de passe, gestionnaire & double authentification (2FA)
4. Mises à jour & dépendances (CMS, plugins, librairies)
5. Sauvegardes automatiques & test de restauration
6. Les en-têtes de sécurité (HSTS, CSP, X-Frame-Options...)
7. Protéger les formulaires (spam, injections, honeypot, rate-limit)
8. Sécuriser WordPress en particulier
9. Sécurité des paiements & e-commerce
10. RGPD & données personnelles (la notification CNIL sous 72 h)
11. Hébergement, accès & principe du moindre privilège
12. Détecter une intrusion (signes, monitoring, uptime)
13. Plan de réaction en cas de piratage
14. Checklist sécurité · FAQ · Glossaire

1. Pourquoi les PME sont des cibles (le mythe du « trop petit »)

« Mon site est trop petit, personne ne va perdre son temps à l'attaquer. » C'est la phrase la plus dangereuse qu'on entend chez les entrepreneurs. Elle repose sur une image fausse du pirate : un humain qui vous vise personnellement. La réalité est tout autre. **La grande majorité des attaques sont automatisées.** Des robots parcourent le web en permanence, testent des millions d'adresses par jour et s'engouffrent dans la première faille venue, sans jamais savoir qui vous êtes ni ce que vous vendez. Un petit site de PME est même une **cible privilégiée** : moins bien protégé qu'une grande entreprise, rarement surveillé, sans équipe informatique. Vous n'êtes pas visé parce que vous êtes gros ou riche, mais parce que vous êtes *accessible*.

Comment fonctionne une attaque automatisée

Une attaque opportuniste typique se déroule en quatre temps, entièrement pilotés par des programmes :

1. **Balayage** : un robot scanne des plages entières d'adresses IP et de domaines à la recherche de sites vivants.
2. **Empreinte** : il identifie la technologie (WordPress ? PrestaShop ? quelle version ?) via des indices publics dans les pages.
3. **Correspondance** : il croise cette empreinte avec un catalogue de failles connues. Une version vulnérable apparaît dans sa liste.
4. **Exploitation** : il envoie le « code d'attaque » correspondant. Si ça marche, il installe une porte dérobée et passe au site suivant.

Tout cela se produit en quelques secondes, sur des milliers de sites à la fois. Aucun humain ne vous « choisit » : c'est une pêche au chalut, et votre site est pris dans le filet s'il présente une prise facile.

Ce qu'un pirate cherche vraiment

Contrairement à l'idée reçue, voler « les secrets de votre entreprise » est rarement le but. Un site compromis a une valeur marchande indépendamment de son contenu :

Type d'attaque	Ce qui se passe concrètement	Conséquence pour vous
Rançongiciel (ransomware)	Vos fichiers et votre base sont chiffrés, on exige une rançon pour la clé.	Site à l'arrêt, données inaccessibles, chantage financier.
Défiguration (defacement)	Votre page d'accueil est remplacée par un message du pirate.	Réputation détruite en quelques heures, perte de confiance.
Vol de données	Emails, mots de passe, coordonnées clients ou bancaires sont exfiltrés.	Obligations RGPD, notification CNIL, plaintes clients, amende.
Détournement (spam / SEO black hat)	Votre serveur envoie du spam ou héberge des pages cachées de casinos/contrefaçons.	Adresse IP blacklistée, déréférencement Google, mails qui n'arrivent plus.
Minage / botnet	Votre hébergement est asservi pour miner de la cryptomonnaie ou attaquer d'autres sites.	Facture d'hébergement qui explose, site ralenti, complice malgré vous.
Hameçonnage hébergé	Le pirate installe une fausse page « banque » ou « impôts » sur votre site pour piéger d'autres victimes.	Votre domaine signalé comme dangereux, courriels bloqués, responsabilité engagée.

Le vrai coût n'est pas la rançon. C'est l'arrêt d'activité, la perte de confiance, le temps de reconstruction, le référencement Google effondré et — si des données personnelles fuient — les obligations légales. Une PME sur deux touchée par une cyberattaque grave met des semaines à s'en remettre, et certaines ne s'en remettent jamais.

Scénario réel : le restaurant qui a « disparu » de Google

Un restaurant de quartier a un site vitrine sous WordPress, jamais mis à jour depuis deux ans. Une extension de galerie photo abandonnée contient une faille connue. Un robot l'exploite en pleine nuit et injecte des centaines de pages invisibles vantant de faux médicaments. Le gérant ne voit rien : la page d'accueil reste normale. Trois semaines plus tard, un client l'appelle : « Votre site est marqué "dangereux" sur Google. » Entre-temps, le référencement s'est effondré, les emails sont blacklistés, les réservations ont chuté. Nettoyage, réexamen Google et reconstruction de la réputation prendront deux mois. **Coût d'une mise à jour évitée : plusieurs milliers d'euros et un été de chiffre d'affaires.**

Le budget « sécurité » d'une PME est plus faible qu'on ne croit

La bonne nouvelle : parce que la plupart des attaques sont automatiques et opportunistes, **quelques mesures de base éliminent l'immense majorité du risque.** Vous n'avez pas besoin d'être imprenable, seulement plus solide que la cible d'à côté, pour que le robot passe son chemin. La plupart des protections décrites ici sont gratuites ou coûtent quelques euros par mois ; l'investissement principal, c'est un peu de discipline et une heure par mois.

Pensez en termes de **rapport effort / risque évité**. Certaines mesures demandent dix minutes et suppriment un risque énorme (2FA, HTTPS forcé, mises à jour), d'autres sont plus techniques et concernent surtout les sites sensibles. Ce guide suit cette hiérarchie : commencez par le haut, faites-le bien, et vous aurez écarté la quasi-totalité des scénarios qui font tomber les PME. La sécurité n'est d'ailleurs pas un état mais une habitude — un entretien régulier, quelques gestes récurrents. Chaque section se termine sur une mini-checklist pour les ancrer.

Mini-checklist — Section 1

- ☐ J'ai compris que les attaques sont automatiques, pas ciblées personnellement.
- ☐ Je sais qu'un site compromis a une valeur marchande même sans données sensibles.
- ☐ J'ai identifié ce que je perdrais concrètement en cas d'incident (CA, réputation, SEO, obligations légales).
- ☐ J'accepte l'idée que « quelques mesures simples » suffisent à écarter l'essentiel du risque.

2. HTTPS, TLS & certificats : le socle

Le petit cadenas dans la barre d'adresse n'est pas cosmétique : c'est la première brique de sécurité, aujourd'hui **non négociable**. HTTPS (le « S » de « sécurisé ») chiffre la conversation entre le navigateur du visiteur et votre serveur grâce au protocole **TLS**. Sans lui, tout circule en clair : un mot de passe, un numéro de carte, un formulaire de contact peuvent être interceptés sur un Wi-Fi public.

Une analogie simple : la carte postale et l'enveloppe

Un site en HTTP, c'est une carte postale : tout le monde sur le trajet — facteur, voisin, pirate du café — peut lire ce qui est écrit. HTTPS met cette carte dans une enveloppe scellée que seul le destinataire ouvre. TLS est la mécanique de l'enveloppe : il négocie une clé secrète entre navigateur et serveur, puis chiffre tout l'échange. Le certificat est la *pièce d'identité* du serveur : il prouve que vous parlez bien à `votre-site.fr` et non à un imposteur.

Ce que HTTPS vous apporte

- **Confidentialité** : personne ne peut lire ce qui transite entre le visiteur et vous.
- **Intégrité** : personne ne peut modifier la page en cours de route (injecter une pub ou un virus).
- **Confiance** : le navigateur affiche un site « sécurisé » au lieu d'un avertissement rouge alarmant.
- **SEO** : Google favorise les sites en HTTPS et pénalise ceux qui restent en HTTP.

Le certificat est gratuit. Grâce à Let's Encrypt, obtenir un certificat TLS ne coûte rien et se renouvelle automatiquement. La plupart des hébergeurs modernes (et toutes les plateformes comme Vercel, Netlify, OVH, o2switch...) l'activent en un clic. Il n'y a plus aucune raison de rester en HTTP.

Les trois réglages à vérifier

1. **Certificat valide et à jour** : vérifiez sa date d'expiration. Un certificat expiré affiche un gros avertissement qui fait fuir vos visiteurs.
2. **Redirection forcée HTTP → HTTPS** : personne ne doit pouvoir atteindre la version non sécurisée. Toute adresse en `http://` doit basculer automatiquement vers `https://`.
3. **Pas de « contenu mixte »** : une page HTTPS qui charge une image ou un script en HTTP casse la sécurité et déclenche un avertissement. Tout doit être servi en HTTPS.

Vérifier son HTTPS en 5 minutes, sans être technicien

Ce que vous vérifiez	Comment faire	Résultat attendu
Le cadenas s'affiche	Cliquez sur l'icône à gauche de l'adresse dans le navigateur.	« Connexion sécurisée », pas d'avertissement.
La date d'expiration du certificat	Dans les détails du cadenas, ou via un outil gratuit comme SSL Labs.	Une échéance future ; renouvellement automatique actif.
La redirection HTTP → HTTPS	Tapez volontairement <code>http://votre-site.fr</code> .	Vous êtes redirigé vers la version <code>https://</code> .
L'absence de contenu mixte	Si le cadenas devient « non sécurisé » sur une page précise, une ressource est en HTTP.	Aucune alerte de contenu mixte sur aucune page.

Attention au renouvellement. Un certificat Let's Encrypt dure 90 jours. Le renouvellement est censé être automatique, mais il arrive qu'il échoue silencieusement (changement de serveur, migration). Programmez une alerte de surveillance qui vous prévient si le certificat approche de l'expiration — c'est une panne d'apparence catastrophique qui se répare pourtant en une minute.

Mini-checklist — Section 2

- ☐ HTTPS actif sur toutes les pages, y compris les images et scripts.
- ☐ Redirection `http://` → `https://` vérifiée à la main.
- ☐ Certificat valide, renouvellement automatique confirmé.
- ☐ Une alerte me préviendra avant l'expiration du certificat.

3. Mots de passe, gestionnaire & double authentification (2FA)

Le maillon le plus faible n'est presque jamais technique : c'est le mot de passe. Les robots ne « cassent » pas des chiffrements complexes ; ils testent des listes de mots de passe volés et de combinaisons évidentes. Si le vôtre est

Motdepasse2026 ou le nom de votre entreprise suivi de !, considérez qu'il est déjà connu.

Pourquoi vos mots de passe fuient (sans que vous le sachiez)

La menace principale n'est pas qu'un pirate « devine » votre mot de passe. C'est qu'un *autre* service où vous étiez inscrit se fasse pirater, et que votre couple email + mot de passe se retrouve dans une base revendue. Les robots testent ensuite ces millions d'identifiants volés partout ailleurs : c'est le « **credential stuffing** » (bourrage d'identifiants). Si vous réutilisez le même mot de passe, une seule fuite ancienne suffit à ouvrir votre site aujourd'hui — **l'unicité compte autant que la longueur.**

Un bon mot de passe en 2026

- **Long avant tout** : au moins 14 caractères. La longueur bat la complexité.
- **Unique par service** : jamais le même mot de passe sur deux sites. Une fuite chez l'un compromet tous les autres.
- **Aléatoire** : pas de date de naissance, pas de prénom, pas de mot du dictionnaire.
- **Jamais partagé par email ou SMS**, et jamais noté dans un fichier « mots de passe.xlsx ».

Mot de passe	Verdict	Pourquoi
Ete2026!	✗ Très faible	Court, prévisible, dans toutes les listes d'attaque.
Boulangerie75!	✗ Faible	Basé sur le métier + code postal, devinable.
Jaime-le-café-a-7h32-le-matin	✓ Bon	Long, personnel, facile à retenir, difficile à deviner.
x9\$Kp2#mQvL7!nR4wZ	✓ Excellent	Généré par un gestionnaire, impossible à forcer.

Gabarit — politique de mots de passe à afficher pour votre équipe

RÈGLES MOTS DE PASSE — [Nom de l'entreprise]

1. Minimum 14 caractères, générés par le gestionnaire.
2. Un mot de passe UNIQUE par service (site, email, hébergeur, banque).
3. Double authentification (2FA) OBLIGATOIRE sur : admin du site, messagerie, hébergeur, banque, réseaux sociaux.
4. Jamais de partage par email/SMS/chat. On partage via le gestionnaire de mots de passe.
5. Départ d'un collaborateur = révocation immédiate de ses accès.
6. En cas de doute sur une fuite : on change, on ne « surveille » pas.

Le gestionnaire de mots de passe : votre meilleur allié

Personne ne peut retenir 40 mots de passe longs et uniques. Un **gestionnaire de mots de passe** (Bitwarden, 1Password, Proton Pass...) résout le problème : il génère, stocke et remplit vos mots de passe de manière chiffrée. Vous ne retenez qu'un seul mot de passe maître, très long ; tout le reste est géré pour vous.

Objection fréquente : « tout mettre au même endroit, n'est-ce pas dangereux ? »

Non : le coffre est chiffré de bout en bout, l'éditeur lui-même ne peut pas le lire, et le vrai danger — réutilisation et post-it — disparaît. Le gestionnaire vous alerte même quand un de vos mots de passe apparaît dans une fuite connue.

Il résout aussi le **partage d'accès** en entreprise. Plutôt que d'envoyer par messagerie le mot de passe de la boîte email commune — qui traîne ensuite dans les historiques —, vous partagez un « coffre d'équipe » : la personne utilise le mot

de passe sans jamais le connaître en clair, et vous lui retirez l'accès d'un clic à son départ, sans le changer pour tout le monde. Pour démarrer sans se décourager, ne migrez pas tout en un jour : commencez par les cinq accès critiques (email principal, hébergeur, domaine, admin du site, banque), donnez-leur un mot de passe neuf et unique, puis remplacez les autres au fil de vos connexions.

La double authentification (2FA) : la ceinture de sécurité

La 2FA ajoute une deuxième preuve d'identité en plus du mot de passe : un code temporaire généré par une application (Google Authenticator, Authy, Aegis...).

Même si un pirate obtient votre mot de passe, il lui manque ce code qui change toutes les 30 secondes. **C'est probablement la mesure la plus rentable de tout ce guide.**

Méthode 2FA	Niveau	Pour qui
Code par SMS	Basique	Mieux que rien ; à éviter sur les comptes critiques (risque de SIM swapping).
Application d'authentification	Bon	Le bon choix par défaut pour tous vos accès.
Clé physique (FIDO2 / passkey)	Excellent	Accès les plus sensibles (banque, hébergeur, admin principal).

Préférez l'application au SMS. Le code par SMS est mieux que rien, mais il peut être intercepté (attaque par « SIM swapping », où le pirate détourne votre numéro chez l'opérateur). Une application d'authentification est plus sûre et fonctionne même sans réseau. Pensez aussi à conserver vos **codes de secours** dans le gestionnaire : ils vous évitent d'être verrouillé hors de votre propre compte en cas de perte du téléphone.

Mini-checklist — Section 3

- ☐ Un gestionnaire de mots de passe installé et adopté par l'équipe.
- ☐ Mot de passe maître long et jamais réutilisé ailleurs.
- ☐ 2FA par application activée sur admin, email, hébergeur, banque, réseaux.
- ☐ Codes de secours 2FA stockés en lieu sûr.
- ☐ Aucun mot de passe partagé par email, SMS ou tableur.

4. Mises à jour & dépendances (CMS, plugins, librairies)

La très grande majorité des sites piratés le sont via une faille **connue et déjà corrigée**, mais que le propriétaire n'avait pas installée. Une mise à jour de sécurité, c'est une porte que l'éditeur a refermée : ne pas l'installer, c'est la laisser ouverte alors que le plan de la maison circule déjà chez les cambrioleurs.

Pourquoi une faille corrigée reste dangereuse

Contre-intuitif mais crucial : le jour où un éditeur publie un correctif, il décrit *publiquement* la faille qu'il vient de boucher. Les pirates lisent ces annonces et fabriquent aussitôt des robots qui cherchent les sites **pas encore mis à jour**. La publication d'un correctif déclenche donc une course : soit vous l'installez vite, soit les robots exploitent le retard. Ce délai s'appelle la « fenêtre de vulnérabilité » — quelques jours au plus pour un site vitrine, quelques heures pour une boutique sur les correctifs critiques. Une mise à jour esthétique peut attendre le rendez-vous mensuel, mais un correctif « sécurité » ou « critique » saute la file.

Où se cachent les failles

- **Le CMS** (WordPress, PrestaShop, Joomla...) : le cœur de votre site.
- **Les plugins et extensions** : la première cause de piratage sur WordPress. Chaque plugin est du code tiers qui peut contenir une faille.
- **Les thèmes**, surtout ceux téléchargés gratuitement sur des sites douteux (souvent piégés).
- **Les librairies** qui font tourner un site sur mesure (les « dépendances » d'un projet Node.js, PHP, etc.).
- **La version du langage serveur** (PHP, Node) : une version obsolète ne reçoit plus de correctifs.

Règle d'or WordPress : moins de plugins = moins de surface d'attaque.
Désinstallez (pas seulement « désactivez ») tout plugin ou thème que vous n'utilisez pas. Un plugin désactivé mais présent reste une faille potentielle.

Comment gérer les mises à jour sans casser son site

1. **Sauvegardez avant** chaque mise à jour majeure (voir section 5).
2. **Testez si possible** sur une copie (environnement de « préproduction ») avant de toucher au site en ligne.
3. **Priorisez les mises à jour de sécurité** : elles ne peuvent pas attendre.
4. **Activez les mises à jour automatiques** au moins pour les correctifs de sécurité mineurs.
5. **Fixez un rendez-vous mensuel** pour passer en revue les mises à jour majeures.

Le rituel mensuel de mise à jour

La sécurité par les mises à jour n'est pas un projet, c'est une habitude. Bloquez un créneau récurrent — 30 minutes le premier lundi du mois suffisent pour un site vitrine — et suivez toujours la même liste. Ce gabarit se colle dans votre agenda ou votre outil de suivi :

Gabarit — routine mensuelle de mise à jour

MISE À JOUR MENSUELLE — le ____ / ____ / _____ · par : _____

- ☐ Sauvegarde complète effectuée AVANT toute action
- ☐ Cœur du CMS à jour (version : _____)
- ☐ Extensions / plugins à jour (nb mis à jour : ____)
- ☐ Thème à jour
- ☐ Version PHP / Node vérifiée (encore supportée ? O / N)
- ☐ Extensions inutiles ou abandonnées SUPPRIMÉES
- ☐ Site testé après mise à jour (accueil, contact, paiement)
- ☐ Aucun message d'erreur, cadenas HTTPS OK
- ☐ Note des anomalies éventuelles : _____

Un plugin abandonné est un danger. Si une extension n'a pas été mise à jour depuis plus d'un an, ou si son auteur a disparu, remplacez-la. Elle ne recevra jamais le correctif de la prochaine faille. Méfiez-vous aussi des extensions « nulled » (versions payantes piratées distribuées gratuitement) : elles sont très souvent livrées avec une porte dérobée préinstallée.

Mini-checklist — Section 4

- ☐ Un rendez-vous mensuel de mise à jour est planté dans l'agenda.
- ☐ Les correctifs de sécurité sont appliqués sans attendre.
- ☐ Aucune extension abandonnée ou « nulled » sur le site.
- ☐ Version du langage serveur (PHP/Node) encore supportée.
- ☐ Chaque mise à jour est précédée d'une sauvegarde et suivie d'un test.

5. Sauvegardes automatiques & test de restauration

La sauvegarde est votre filet de sécurité ultime. Quoi qu'il arrive — piratage, erreur humaine, mise à jour ratée, panne serveur — une bonne sauvegarde vous permet de tout remonter : c'est la différence entre « on a perdu deux heures » et « on a perdu l'entreprise ».

La règle 3-2-1

Une méthode simple et éprouvée pour ne jamais tout perdre :

- **3** copies de vos données (l'original + 2 sauvegardes).
- **2** supports différents (par ex. le serveur + un stockage cloud).
- **1** copie hors site, déconnectée, à l'abri d'un rançongiciel.

Gabarit — plan de sauvegarde 3-2-1

PLAN DE SAUVEGARDE — [Nom du site]

Copie 1 (originale) : sur le serveur de production

Copie 2 (locale/proche) : _____ · fréquence : _____

Copie 3 (hors site, déconnectée) : _____ · fréquence : _____

Contenu sauvegardé : [] fichiers [] base de données [] config

Rétention : garder ___ jours / ___ semaines / ___ mois d'historique

Chiffrement des sauvegardes : 0 / N

Test de restauration : 2x/an, prochain le ___ / ___ / _____

Responsable : _____

Le piège du rançongiciel : si votre unique sauvegarde est branchée en permanence sur le même serveur, elle sera chiffrée en même temps que le reste. Une sauvegarde qui vous sauve est une sauvegarde *déconnectée* ou stockée sur un service tiers indépendant.

Ce qu'une bonne sauvegarde doit couvrir

Élément	Pourquoi c'est vital	Fréquence conseillée
Les fichiers du site	Thème, extensions, images, code : votre site en lui-même.	Quotidienne à hebdomadaire
La base de données	Vos contenus, commandes, clients, comptes. Le plus précieux.	Quotidienne (e-commerce : plusieurs fois/jour)
La configuration	Réglages serveur, certificats, variables d'environnement.	À chaque changement

La notion de rétention : ne pas sauvegarder que « hier »

Une erreur classique : ne conserver que la sauvegarde de la nuit dernière, qui écrase la précédente. Or une intrusion peut rester discrète plusieurs jours : votre unique version contient peut-être déjà la porte dérobée du pirate. Conservez donc un **historique** — par exemple 7 sauvegardes quotidiennes, 4 hebdomadaires et 3 mensuelles — pour pouvoir revenir à un point *antérieur* à la compromission. Deux questions calibrent le reste : **combien de données puis-je perdre ?** (une sauvegarde quotidienne = une journée perdue au pire ; trop pour une boutique, qui sauvegarde plusieurs fois par jour) et **en combien de temps dois-je être de nouveau en ligne ?** (une restauration de six heures ne convient pas si chaque heure d'arrêt coûte cher).

Dernier réflexe : la **surveillance des sauvegardes elles-mêmes**. Une sauvegarde automatique peut échouer sans bruit pendant des mois (quota plein, identifiants expirés, service en panne). Configurez une alerte en cas d'échec : une sauvegarde qu'on croit active mais morte depuis trois mois est pire que pas de sauvegarde, car elle endort la vigilance.

Une sauvegarde jamais testée n'est pas une sauvegarde. Au moins deux fois par an, faites un vrai test de restauration sur un site de test. Beaucoup de PME découvrent le jour du drame que leurs sauvegardes étaient corrompues ou incomplètes. Testez avant, pas pendant la crise.

Mini-checklist — Section 5

- ☐ Sauvegardes automatiques des fichiers ET de la base de données.
- ☐ Au moins une copie hors site, déconnectée du serveur.
- ☐ Un historique (rétention) permettant de remonter avant une intrusion.
- ☐ Sauvegardes chiffrées si elles contiennent des données personnelles.
- ☐ Un test de restauration réussi dans les 6 derniers mois.

6. Les en-têtes de sécurité (HSTS, CSP, X-Frame-Options...)

Les « en-têtes de sécurité » (HTTP security headers) sont des instructions invisibles que votre serveur envoie au navigateur pour lui dire comment se comporter prudemment. Le visiteur ne les voit jamais, mais ils ferment des portes entières d'attaques courantes. C'est de la sécurité « gratuite » : quelques lignes de configuration qui protègent tous vos visiteurs.

Les en-têtes essentiels, expliqués simplement

En-tête	Ce qu'il fait, en clair
HSTS (Strict-Transport-Security)	Force le navigateur à toujours utiliser HTTPS, même si quelqu'un tape l'adresse en HTTP. Empêche les attaques de « rétrogradation ».
CSP (Content-Security-Policy)	Le videur de la boîte : dit au navigateur quels scripts et ressources il a le droit de charger. Bloque l'injection de code malveillant (XSS).
X-Frame-Options	Empêche qu'on affiche votre site dans une fenêtre invisible pour piéger vos visiteurs (« clickjacking »).
X-Content-Type-Options	Empêche le navigateur de « deviner » le type d'un fichier et d'exécuter par erreur un fichier piégé.
Referrer-Policy	Limite les informations envoyées aux sites tiers quand un visiteur clique sur un lien sortant.
Permissions-Policy	Décide quelles fonctions (caméra, micro, géolocalisation) une page peut demander.

Gabarit — en-têtes de sécurité recommandés

```
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
Content-Security-Policy: default-src 'self'; img-src 'self' https;;
script-src 'self'
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
```

Deux attaques que ces en-têtes bloquent

Le clickjacking. Un pirate crée une fausse page « Gagnez un iPhone, cliquez ici » et superpose par-dessus *votre* site, rendu transparent, positionné pour que le vrai bouton cliqué soit « Supprimer mon compte » ou « Valider le paiement ». Le visiteur croit jouer, il agit à son insu sur votre site. L'en-tête `X-Frame-Options: DENY` interdit d'afficher votre site dans le cadre d'un autre : l'attaque devient impossible.

Le XSS (cross-site scripting) injecte un script malveillant qui s'exécute chez vos visiteurs — par exemple un commentaire piégé qui vole les identifiants de session de chaque lecteur. Sans CSP, le navigateur l'exécute, car il vient « de votre site ». Avec un CSP bien réglé, il n'exécute que les scripts explicitement autorisés (votre domaine, ou porteurs d'un « nonce » que vous seul générez) ; le script injecté reste inerte. C'est la logique du videur : la liste des invités est établie à l'avance, tout le reste reste à la porte.

Vérifier ses en-têtes gratuitement

Des outils gratuits (securityheaders.com, l'observatoire de Mozilla) analysent votre site et vous donnent une note avec les en-têtes manquants. Lancez le test, notez ce qui manque, faites poser les en-têtes par votre développeur : le gain de sécurité est disproportionné par rapport à l'effort.

Le cas du CSP : c'est l'en-tête le plus puissant mais aussi le plus délicat, car trop strict il peut casser des fonctionnalités (widgets, statistiques, paiement). On le déploie progressivement, en mode « observation » d'abord (mode `Report-Only` qui signale sans bloquer). Sur une application moderne comme un site Next.js, la politique CSP se pose via ces en-têtes (avec un « nonce » unique par page pour autoriser vos propres scripts). L'idée à retenir : on autorise explicitement ce dont on a besoin, et on refuse tout le reste par défaut.

Mini-checklist — Section 6

- ☐ HSTS actif pour forcer HTTPS en permanence.
- ☐ X-Frame-Options / X-Content-Type-Options / Referrer-Policy posés.
- ☐ CSP déployé, d'abord en mode observation puis en blocage.
- ☐ Note obtenue sur securityheaders.com et manques corrigés.

7. Protéger les formulaires (spam, injections, honeypot, rate-limit)

Chaque formulaire de votre site — contact, inscription, commentaire, connexion — est une porte d'entrée. C'est un endroit où un inconnu envoie du texte à votre serveur. S'il n'est pas protégé, il devient un aimant à spam et une faille potentielle. Voici comment le blinder sans dégrader l'expérience de vos vrais visiteurs.

Un principe gouverne toute cette section : **tout ce qui vient de l'extérieur est suspect jusqu'à preuve du contraire**. Le texte qu'un visiteur tape dans un champ n'est pas une donnée amicale, c'est une matière première potentiellement piégée. Les développeurs expérimentés adoptent ce réflexe de méfiance non par paranoïa, mais parce que c'est là que se logent la plupart des attaques applicatives. Votre rôle est de vous assurer qu'il est appliqué, et de ne jamais accepter un formulaire « posé à la va-vite ».

Contre le spam automatique

- **Le honeypot (pot de miel)** : un champ caché, invisible pour l'humain mais que les robots remplissent bêtement. Si ce champ est rempli, on rejette silencieusement l'envoi. Discret et redoutablement efficace.
- **Le rate-limiting (limitation de débit)** : on limite le nombre d'envois par minute depuis une même adresse. Un humain remplit un formulaire toutes les quelques minutes ; un robot en tente des centaines.
- **Un captcha discret** (type hCaptcha ou Turnstile) sur les formulaires sensibles, sans imposer les corvées de « sélectionnez les feux tricolores » à vos clients.

Contre les injections

Les attaques les plus classiques consistent à glisser du code malveillant dans un champ, en espérant que le serveur l'exécute (injection SQL) ou qu'il s'affiche chez un autre visiteur (XSS). La parade tient en une règle d'or : **ne jamais faire confiance à ce que l'utilisateur saisit**.

- **Valider** chaque donnée reçue (un email ressemble-t-il à un email ? un numéro à un numéro ?).
- **Échapper** les données avant de les afficher, pour qu'un script saisi apparaisse comme du texte inoffensif.
- **Utiliser des requêtes paramétrées** côté base de données (le sujet est technique, mais tout développeur sérieux le fait par défaut).

Comprendre l'injection SQL en une image

En coulisses, un serveur construit une phrase pour interroger la base : « donne-moi l'utilisateur dont l'email est [ce que la personne a tapé] ». S'il colle bêtement la saisie dans cette phrase, un pirate peut taper non pas un email mais une *instruction déguisée* qui la transforme en « donne-moi tous les utilisateurs » ou « supprime la table ». C'est l'injection SQL. La parade — les **requêtes paramétrées** — ne mélange jamais saisie et instruction : la saisie est traitée comme une simple valeur, jamais comme une commande. Votre rôle est de vous assurer que votre développeur l'applique partout.

Formulaire	Protections minimales
Contact	Honeypot + rate-limit + validation email
Inscription / création de compte	Captcha discret + validation + vérification par email
Connexion	Rate-limit + blocage après N échecs + 2FA
Commentaire / avis	Honeypot + modération + échappement à l'affichage
Recherche interne	Requêtes paramétrées + échappement du terme affiché

Le formulaire de connexion mérite une attention spéciale. C'est la cible n°1 des robots. Combinez 2FA, rate-limiting (blocage après plusieurs échecs) et — sur WordPress — le masquage de l'adresse d'administration par défaut (`/wp-admin` , `/wp-login.php`).

Mini-checklist — Section 7

- ☐ Honeypot et/ou captcha discret sur les formulaires publics.
- ☐ Rate-limiting actif, surtout sur la connexion.
- ☐ Toutes les saisies validées côté serveur (pas seulement côté navigateur).
- ☐ Requêtes paramétrées confirmées auprès du développeur.
- ☐ Données échappées avant affichage (protection XSS).

8. Sécuriser WordPress en particulier

WordPress fait tourner une part énorme du web, ce qui en fait la cible la plus attaquée — non parce qu’il serait mal conçu, mais parce qu’il est partout. Si votre site est sous WordPress, cette section rassemble les réglages qui vous mettent au-dessus de l’immense majorité des sites vulnérables. La bonne nouvelle : bien tenu, WordPress est parfaitement sûr.

D’où vient la mauvaise réputation ? WordPress lui-même — le « cœur » développé par des milliers de contributeurs — est plutôt bien sécurisé et corrigé vite. Le problème vient de l’écosystème : des dizaines de milliers d’extensions et de thèmes tiers de qualité inégale, dont certains abandonnés ou négligés. Ajoutez des installations laissées en réglages par défaut, et vous obtenez une immense population de sites faciles à attaquer. Votre objectif n’est pas d’être parfait : c’est de sortir de cette population-là.

Les réglages qui font 90 % du travail

- **Supprimer le compte `admin`** : c’est le premier identifiant que les robots testent. Créez un administrateur au nom non devinable, puis supprimez `admin`.
- **Masquer / limiter la page de connexion** : changez l’URL de `/wp-login.php` et bloquez les tentatives répétées.
- **Désactiver l’éditeur de fichiers intégré** : dans le tableau de bord, un pirate qui prend un compte admin peut sinon modifier votre code directement depuis le navigateur.
- **Interdire l’exécution de code dans le dossier des médias** (`/wp-content/uploads/`) : ce dossier ne doit contenir que des fichiers, jamais des scripts exécutables.
- **Réduire les plugins au strict nécessaire** et n’installer que des extensions maintenues et bien notées.
- **Un plugin de sécurité reconnu** (type Wordfence, Solid Security...) pour le pare-feu, le scan et la limitation des connexions.

Réglage	Risque évité	Effort
Supprimer le compte <code>admin</code>	Attaque par force sur l'identifiant le plus courant	5 min
Limiter les tentatives de connexion	Bourrage de mots de passe	Plugin, 10 min
2FA sur les comptes admin	Vol de mot de passe	Plugin, 10 min
Désactiver l'éditeur de thème/plugin	Modification de code après compromission	1 ligne de config
Bloquer les scripts dans <code>/uploads/</code>	Porte dérobée déposée via un envoi de fichier	Config serveur
Retirer les extensions inutiles	Réduction de la surface d'attaque	15 min

Gabarit — durcissement wp-config (extraits à faire poser)

```
// Interdire l'éditeur de fichiers dans l'admin
define('DISALLOW_FILE_EDIT', true);

// Forcer les connexions admin en HTTPS
define('FORCE_SSL_ADMIN', true);

// Clés de sécurité uniques (à régénérer via l'outil officiel WordPress)
// AUTH_KEY, SECURE_AUTH_KEY, LOGGED_IN_KEY, NONCE_KEY ...

// Bon réflexe complémentaire :
// - fichier wp-config.php en lecture seule
// - désactiver l'édition de code dans /uploads/ (règle serveur)
```

Le danger n°1 reste les extensions. Un thème « premium gratuit » téléchargé sur un site de warez, une extension abandonnée depuis deux ans, une galerie photo trop populaire : c'est presque toujours par là que WordPress se fait pirater. Auditez vos plugins deux fois par an et supprimez sans pitié tout ce qui n'est plus indispensable ou plus maintenu.

Mini-checklist — Section 8 (WordPress)

- ☐ Aucun compte nommé `admin` .
- ☐ Page de connexion protégée (URL modifiée + limitation des tentatives).
- ☐ 2FA sur tous les comptes administrateurs.
- ☐ Éditeur de fichiers désactivé, `/uploads/` non exécutable.
- ☐ Plugin de sécurité reconnu installé et configuré.
- ☐ Extensions et thèmes inutiles ou abandonnés supprimés.

9. Sécurité des paiements & e-commerce

Dès que de l'argent circule, les enjeux changent d'échelle : une boutique manipule données bancaires, commandes et comptes clients, et devient une cible de grande valeur. La bonne nouvelle : une architecture de paiement bien pensée vous décharge de la partie la plus risquée. Encore faut-il faire les bons choix.

Ne touchez jamais les numéros de carte

La règle d'or du e-commerce : **vous ne devez jamais voir, stocker ni transmettre les numéros de carte bancaire de vos clients**. Confiez cela à un prestataire de paiement spécialisé (Stripe, PayPlug, Mollie, PayPal...).

Concrètement, le client saisit sa carte dans un formulaire hébergé par le prestataire, pas par vous ; vous ne recevez qu'un jeton et une confirmation. Ainsi, même si votre site est piraté, il n'y a aucune donnée bancaire à voler chez vous. C'est le principe qui allège aussi vos obligations réglementaires (la norme **PCI-DSS**, qui encadre le traitement des cartes).

C'est de loin la décision de sécurité la plus importante d'une boutique. En déléguant, vous transférez la partie la plus lourde et la plus risquée — la conservation de données bancaires — à un acteur dont c'est le métier, qui investit des millions et se soumet à des audits réguliers. Vous vous concentrez sur le reste : la sécurité de votre site, de vos comptes clients et de vos processus. Vouloir « tout gérer soi-même » pour économiser quelques dixièmes de commission est un très mauvais calcul pour une PME.

Modèle	Qui voit la carte	Votre exposition
Redirection / champ hébergé (recommandé)	Le prestataire seul	Minimale : aucune donnée carte chez vous
Formulaire sur votre site relayé au prestataire	Transite par votre site	Élevée : conformité PCI lourde
Stockage des cartes chez vous	Vous	À proscrire pour une PME

3-D Secure et lutte contre la fraude

3-D Secure (la validation par l'appli bancaire ou un code) déplace la responsabilité de la fraude vers la banque du client et bloque une grande partie des paiements frauduleux. Activez-le. Complétez avec les outils anti-fraude de votre prestataire (scoring des transactions, blocage géographique, plafonds), et surveillez les signaux : multiplication de petites commandes test, adresses de livraison incohérentes, pics de paiements refusés.

Les fraudes spécifiques à surveiller

- **Le web skimming (Magecart)** : un script malveillant injecté dans votre page de paiement copie discrètement les cartes au moment de la saisie. La parade : CSP stricte, surveillance d'intégrité des scripts, et champ de paiement hébergé par le prestataire.
- **Le card testing** : des fraudeurs testent des milliers de numéros volés via votre formulaire pour repérer ceux qui marchent. La parade : captcha, rate-limiting et alertes sur les taux de refus anormaux.
- **La prise de contrôle de compte client** : réutilisation d'identifiants volés pour vider un compte fidélité ou changer une adresse. La parade : 2FA côté client, alertes de connexion inhabituelle.

Gabarit — check e-commerce avant mise en ligne

SÉCURITÉ BOUTIQUE — [Nom de la boutique]

- ☐ Paiement via prestataire (Stripe/PayPlug/Mollie...), champ hébergé
- ☐ Aucune donnée carte stockée sur notre serveur
- ☐ 3-D Secure activé
- ☐ Outils anti-fraude du prestataire activés (scoring, plafonds)
- ☐ CSP stricte sur la page de paiement (anti-skimming)
- ☐ Rate-limit + captcha au paiement (anti card testing)
- ☐ Comptes clients : 2FA proposée, mots de passe hachés
- ☐ Sauvegardes base de données plusieurs fois par jour
- ☐ Politique de confidentialité + mentions paiement à jour
- ☐ Webhooks du prestataire vérifiés (signature) et sécurisés

Sécurisez les webhooks de paiement. Votre boutique reçoit du prestataire des notifications automatiques (« paiement confirmé »). Un pirate qui devine cette adresse pourrait envoyer de fausses confirmations et déclencher des expéditions non payées. Vérifiez toujours la *signature* de ces notifications : c'est le sceau qui prouve qu'elles viennent bien du prestataire.

Mini-checklist — Section 9 (e-commerce)

- ☐ Aucune donnée de carte stockée ou traitée chez moi.
- ☐ 3-D Secure et outils anti-fraude activés.
- ☐ Page de paiement protégée par CSP (anti-skimming).
- ☐ Rate-limit et captcha contre le card testing.
- ☐ Webhooks de paiement vérifiés par signature.
- ☐ Sauvegardes de la base plusieurs fois par jour.

10. RGPD & données personnelles (la notification CNIL sous 72 h)

Dès que votre site collecte la moindre donnée personnelle — un email de contact, un compte client, une commande — vous entrez dans le champ du RGPD. Ce n'est pas qu'une affaire de bandeau cookies : c'est une obligation de **protéger** ces données. La sécurité et le RGPD sont les deux faces d'une même pièce.

Vos obligations de base

- **Minimiser** : ne collectez que ce dont vous avez réellement besoin. Une donnée que vous n'avez pas ne peut pas fuiter.
- **Sécuriser** : chiffrement (HTTPS), accès restreints, mots de passe des utilisateurs stockés « hachés » (jamais en clair).
- **Informé** : une politique de confidentialité claire, expliquant ce que vous collectez et pourquoi.
- **Consentir** : recueillir un consentement libre pour les cookies non essentiels et le marketing.
- **Permettre l'accès et l'effacement** : un client peut demander ses données ou leur suppression.

La règle des 72 heures. En cas de fuite de données personnelles (violation), vous avez **72 heures** pour la notifier à la CNIL, et vous devez informer les personnes concernées si le risque pour elles est élevé. Ne pas le faire est une faute qui aggrave les sanctions. Préparez ce réflexe *avant* l'incident, pas pendant.

Le registre des traitements : votre inventaire des données

Le RGPD impose de tenir un **registre des traitements** : la liste de ce que vous collectez, pourquoi, où et combien de temps. Loin d'être une formalité, c'est un outil de sécurité — on ne protège bien que ce qu'on a recensé. Voici un gabarit minimal à tenir à jour :

Gabarit — registre des traitements (une ligne par usage)

TRAITEMENT : _____ (ex. « Formulaire de contact »)
Finalité (pourquoi) : _____
Données collectées : _____
Base légale : consentement / contrat / intérêt légitime / obligation
Où c'est stocké : _____
Qui y a accès : _____
Sous-traitants (hébergeur, emailing, paiement) : _____
Durée de conservation : _____
Mesures de sécurité : HTTPS / accès restreint / chiffrement / ...

La minimisation, meilleure amie de la sécurité

Retenez ce principe libérateur : **la donnée la plus sûre est celle que vous ne collectez pas**. Avant d'ajouter un champ à un formulaire, demandez-vous s'il est vraiment utile. Chaque donnée en moins, c'est une responsabilité et un risque de fuite en moins — et une confiance en plus. Au-delà de la contrainte légale, un client qui vous confie ses informations veut les savoir entre de bonnes mains : la conformité RGPD bien menée devient un atout commercial, pas seulement une case à cocher.

Mini-checklist — Section 10 (RGPD)

- ☐ Un registre des traitements tenu et à jour.
- ☐ Politique de confidentialité claire et accessible.
- ☐ Consentement recueilli pour cookies non essentiels et marketing.
- ☐ Mots de passe utilisateurs hachés, accès restreints.
- ☐ Procédure de notification CNIL sous 72 h préparée à l'avance.
- ☐ Seules les données réellement utiles sont collectées.

11. Hébergement, accès & principe du moindre privilège

La sécurité ne s'arrête pas au code : elle dépend aussi de qui a les clés, et de combien de clés existent. Le **principe du moindre privilège** est simple : chaque personne, chaque service, chaque compte ne doit avoir accès qu'à ce dont il a strictement besoin, ni plus.

Bien choisir son hébergement

- **Un hébergeur sérieux** qui maintient ses serveurs à jour et propose des sauvegardes, un pare-feu et un support réactif.
- **L'isolation** : évitez de mettre 20 sites sur le même hébergement partagé bas de gamme, où la faille de l'un contamine les autres.
- **Un pare-feu applicatif (WAF)** qui filtre le trafic malveillant avant qu'il n'atteigne votre site.

Discipliner les accès

1. **Un compte par personne**, jamais un compte « admin » partagé par toute l'équipe. Sinon, impossible de savoir qui a fait quoi.
2. **Le bon rôle pour le bon besoin** : un rédacteur n'a pas besoin des droits d'administrateur. Attribuez le rôle le plus limité possible.
3. **Révocation immédiate** à chaque départ de collaborateur ou fin de mission d'un prestataire.
4. **Rotation des secrets** : les clés d'API et mots de passe techniques ne se collent jamais dans un email ou un chat, et se changent en cas de doute.
5. **Inventaire des accès** : sachez à tout moment qui a accès à quoi. Un accès oublié est une porte oubliée.

Le registre des accès : savoir qui a les clés

La plupart des PME seraient incapables de dire qui a accès à leur hébergeur, leur domaine ou leur boîte email principale. C'est un angle mort classique : l'ancien

stagiaire, le prestataire d'il y a deux ans, le cousin qui a « installé le site »... Tenez un registre simple et révisiez-le deux fois par an :

Un accès mérite une mention spéciale : le **nom de domaine**. Qui contrôle le compte chez le bureau d'enregistrement (le « registrar ») ? Beaucoup d'entrepreneurs découvrent, en changeant de prestataire, que leur domaine est enregistré au nom de l'ancien développeur — ou qu'ils n'ont plus les identifiants. Or perdre la main sur son domaine, c'est perdre site, emails et référencement d'un coup. Vérifiez qu'il est à votre nom, que vous avez les accès, et activez le « verrou de transfert » qui empêche qu'on le déplace à votre insu.

Gabarit — registre des accès

SERVICE	PERSONNE	RÔLE	2FA	REVU LE
-----	-----	-----	-----	-----
Admin du site	_____	Admin	0/N	__/__/__
Hébergeur	_____	_____	0/N	__/__/__
Nom de domaine	_____	_____	0/N	__/__/__
Email principal	_____	_____	0/N	__/__/__
Prestataire de paiement	_____	_____	0/N	__/__/__
Réseaux sociaux	_____	_____	0/N	__/__/__

Départ / fin de mission → révoquer le jour même.

Le compte « admin » par défaut est un cadeau aux pirates. Sur WordPress, ne gardez jamais l'identifiant `admin` : les robots le testent en premier. Créez un compte administrateur avec un nom d'utilisateur non devinable et supprimez `admin`.

Mini-checklist — Section 11

- ☐ Hébergeur sérieux, à jour, avec sauvegardes et pare-feu.
- ☐ Un compte nominatif par personne, aucun compte partagé.
- ☐ Chaque compte a le rôle le plus restreint possible.
- ☐ Un registre des accès tenu et révisé deux fois par an.
- ☐ Révocation immédiate à chaque départ.

12. Détecter une intrusion (signes, monitoring, uptime)

La meilleure défense n'est jamais parfaite. La question n'est pas seulement « comment empêcher », mais « combien de temps me faut-il pour **savoir** ». Un site peut rester compromis des semaines avant que son propriétaire s'en aperçoive — souvent parce qu'un client ou Google le prévient, ce qui est déjà trop tard.

Ce « temps de détection » — le délai entre l'intrusion et le moment où vous vous en rendez compte — décide de l'ampleur des dégâts : pages de spam indexées, données exfiltrées, réputation d'expéditeur détruite, porte dérobée qui s'enracine. Le réduire ne demande pas de compétences pointues : quelques capteurs qui vous préviennent automatiquement suffisent, pour ne pas dépendre du hasard ou d'un client mécontent.

Les signes qui doivent alerter

- Votre site est soudainement **lent** ou consomme des ressources anormales.
- Des **pages inconnues** apparaissent (souvent liées à des casinos, contrefaçons, pharmacies).
- Google affiche un **avertissement** « **site trompeur** » ou vous envoie une alerte dans la Search Console.
- Vos **emails n'arrivent plus** (votre domaine a été blacklisté pour spam).
- Des **connexions** à des heures ou depuis des pays inhabituels dans vos journaux.
- Des **fichiers modifiés** récemment sans que vous y ayez touché.

Mettre en place une surveillance

- **Monitoring de disponibilité (uptime)** : un service qui vous alerte en quelques minutes si votre site tombe.
- **Surveillance d'intégrité des fichiers** : une alerte dès qu'un fichier du site est modifié de manière inattendue.

- **Scan de malware** régulier (plugins de sécurité, services externes).
- **Google Search Console** : elle vous prévient gratuitement en cas de problème de sécurité détecté par Google.
- **Journaux (logs)** : gardez-les et consultez-les. En cas d'incident, ce sont vos caméras de surveillance.

Outil	Ce qu'il surveille	Coût typique
Monitoring uptime	Site en ligne / hors ligne, temps de réponse	Gratuit à quelques €/mois
Search Console (Google)	Alertes sécurité, pages piratées détectées par Google	Gratuit
Scan de malware / intégrité	Fichiers modifiés, code injecté	Souvent inclus dans un plugin de sécurité
Surveillance du certificat	Expiration TLS imminente	Gratuit
Surveillance de blacklist mail	Domaine signalé comme spam	Gratuit à faible coût

Détecter tôt change tout. Une intrusion repérée en une heure se nettoie souvent en une matinée. La même intrusion découverte trois semaines plus tard, quand Google vous a déréféréncé et que vos clients ont vu la défiguration, coûte cent fois plus cher.

Mini-checklist — Section 12

- ☐ Monitoring de disponibilité actif avec alerte immédiate.
- ☐ Google Search Console connectée et surveillée.
- ☐ Scan de malware / intégrité des fichiers en place.
- ☐ Journaux conservés et consultables en cas d'incident.
- ☐ Surveillance du certificat et de la réputation mail.

13. Plan de réaction en cas de piratage

Malgré toutes les précautions, un incident peut survenir. Ce qui fait la différence, c'est d'avoir un plan clair **avant** la panique : improviser à 2 h du matin, sous stress, en supprimant des fichiers au hasard, aggrave presque toujours la situation. Voici la marche à suivre.

1. **Rester calme et ne rien détruire.** Ne supprimez rien dans la précipitation : vous auriez besoin des traces pour comprendre l'attaque.
2. **Isoler.** Mettez le site en maintenance ou hors ligne pour stopper la propagation et protéger vos visiteurs.
3. **Changer tous les accès.** Mots de passe admin, hébergeur, base de données, FTP, emails. Depuis un ordinateur sain.
4. **Constater et documenter.** Faites des captures, notez l'heure, sauvegardez les journaux. Utile pour la CNIL et une éventuelle plainte.
5. **Restaurer depuis une sauvegarde saine** antérieure à l'intrusion — d'où l'importance des sauvegardes datées (section 5).
6. **Corriger la faille.** Restaurer sans comprendre la porte d'entrée, c'est se faire repirater dans la foulée. Identifiez la cause.
7. **Mettre à jour et durcir** : correctifs, en-têtes, 2FA, revue des accès.
8. **Notifier si des données ont fuité** : CNIL sous 72 h, personnes concernées si nécessaire.
9. **Surveiller renforcé** pendant les semaines suivantes, au cas où une porte dérobée aurait survécu.

Votre fiche d'urgence à remplir maintenant

Le plan ci-dessus ne vaut que si les informations utiles sont accessibles *hors du site* (car le site peut être justement inaccessible). Remplissez cette fiche et gardez-la ailleurs (papier, gestionnaire de mots de passe, document hors ligne) :

Gabarit — fiche d'urgence incident

FICHE D'URGENCE — [Nom du site] · à conserver HORS du site

Hébergeur : _____ · support / tél : _____

Registrar (domaine) : _____

Prestataire de paiement : _____

Développeur / agence : _____

Où sont les sauvegardes : _____

Comment mettre le site en maintenance : _____

Contact CNIL (violation de données) : cnil.fr – notification

Assurance cyber (si souscrite) : _____ · n° police ____

Ordre des actions : ISOLER → CHANGER ACCÈS → DOCUMENTER →

RESTAURER (sauvegarde saine) → CORRIGER LA FAILLE → NOTIFIER

Ne payez jamais une rançon sans conseil. Payer ne garantit rien : vous n'avez aucune assurance de récupérer vos données, et vous vous désignez comme cible « qui paie ». Une sauvegarde saine reste la meilleure réponse à un rançongiciel. En cas de doute, faites-vous accompagner par un professionnel.

Mini-checklist — Section 13

- ☐ Un plan de réaction écrit, connu de l'équipe.
- ☐ Une fiche d'urgence remplie et conservée hors du site.
- ☐ Je sais où sont mes sauvegardes saines et comment restaurer.
- ☐ Je connais mon réflexe CNIL (72 h) en cas de fuite.
- ☐ Je n'improviserai pas de suppression de fichiers sous stress.

Vous préférez dormir tranquille ?

Sécuriser un site demande du temps, de la vigilance et un peu de technique. Chez My-DTM, on audite votre site, on corrige les failles, on met en place sauvegardes, en-têtes de sécurité et surveillance — et on veille

pour vous. Vous vous concentrez sur votre activité, on protège votre présence en ligne.

→ **Découvrir notre service Sécurité web — my-dtm.fr/services/securite-web**

14. Checklist sécurité · FAQ · Glossaire

Votre checklist sécurité essentielle

- ☐ HTTPS actif partout, redirection HTTP → HTTPS forcée, certificat valide.
- ☐ Mots de passe longs, uniques, dans un gestionnaire.
- ☐ 2FA activée sur tous les accès sensibles (admin, email, hébergeur, banque).
- ☐ CMS, plugins, thèmes et dépendances à jour ; extensions inutiles supprimées.
- ☐ Sauvegardes automatiques, déconnectées, avec historique et un test de restauration réussi.
- ☐ En-têtes de sécurité en place (HSTS, CSP, X-Frame-Options...).
- ☐ Formulaires protégés (honeypot, rate-limit, validation des saisies).
- ☐ WordPress durci (compte admin supprimé, connexion protégée, 2FA, plugins audités).
- ☐ Paiements délégués à un prestataire, 3-D Secure et anti-fraude actifs.
- ☐ Politique de confidentialité, registre des traitements et conformité RGPD à jour.
- ☐ Un compte par personne, moindre privilège, registre des accès révisé.
- ☐ Monitoring uptime + Search Console + scan malware actifs.
- ☐ Un plan de réaction écrit et une fiche d'urgence conservée hors du site.

FAQ

Mon site est vraiment petit, dois-je vraiment m'en soucier ?

Oui. Les attaques sont automatiques et opportunistes : elles ne vous choisissent pas, elles trouvent une faille. Un petit site mal protégé est une cible plus facile qu'un gros site bien défendu.

WordPress est-il moins sûr qu'un autre système ?

Non : il est simplement le plus répandu, donc le plus visé. Bien maintenu (mises à

jour, peu de plugins, 2FA), il est parfaitement sûr. Le danger vient presque toujours des extensions négligées.

Un certificat HTTPS suffit-il à sécuriser mon site ?

Non. HTTPS chiffre la connexion, mais ne protège ni contre les mots de passe faibles, ni contre les failles de plugins, ni contre le spam. C'est une brique indispensable, pas la maison entière.

À quelle fréquence dois-je sauvegarder ?

Au minimum une fois par jour pour la base de données d'un site actif, et à chaque changement important. Pour un e-commerce, plusieurs fois par jour. Et surtout : testez la restauration au moins deux fois par an.

Dois-je stocker les cartes bancaires de mes clients pour faciliter le rachat ?

Non, jamais chez vous. Confiez cela à votre prestataire de paiement, qui gère le stockage sécurisé (« carte enregistrée ») à votre place. Vous ne devez ni voir ni conserver les numéros de carte.

Le captcha n'agace-t-il pas mes visiteurs ?

Les captchas modernes (Turnstile, hCaptcha) sont le plus souvent invisibles et ne se déclenchent qu'en cas de doute ; le honeypot est totalement transparent. On se protège sans dégrader l'expérience.

Ai-je besoin d'une assurance cyber ?

Pour une petite structure, elle peut couvrir la remise en état, l'accompagnement juridique et parfois la perte d'exploitation. Non obligatoire, mais à évaluer si votre activité dépend fortement de votre site.

Glossaire

- **HTTPS / TLS** : protocole qui chiffre les échanges entre le visiteur et votre site.
- **2FA** : double authentification, une deuxième preuve d'identité en plus du mot de passe.
- **CMS** : système de gestion de contenu (WordPress, PrestaShop...) qui fait tourner votre site.
- **CSP** : politique de sécurité du contenu, en-tête qui contrôle ce que le navigateur peut charger.
- **HSTS** : en-tête qui force l'usage permanent de HTTPS.

- **XSS / injection SQL** : attaques par insertion de code malveillant dans un formulaire.
- **Honeypot** : champ piège invisible destiné à démasquer les robots spammeurs.
- **Rate-limiting** : limitation du nombre de requêtes par période, contre les attaques en force.
- **Credential stuffing** : bourrage d'identifiants volés testés en masse sur d'autres sites.
- **Rançongiciel (ransomware)** : logiciel qui chiffre vos données pour exiger une rançon.
- **WAF** : pare-feu applicatif qui filtre le trafic malveillant.
- **Moindre privilège** : principe d'accorder à chacun le minimum d'accès nécessaire.
- **PCI-DSS** : norme de sécurité encadrant le traitement des données de cartes bancaires.
- **3-D Secure** : validation renforcée d'un paiement par la banque du client.
- **Web skimming (Magecart)** : vol de cartes via un script injecté dans la page de paiement.
- **RGPD** : règlement européen sur la protection des données personnelles.